

# Data Protection Policy — United Arab Emirates Operations

**Document Classification:** Internal — Restricted

**Policy Owner:** Chief Compliance Officer & Data Protection Officer

**Version:** 3.0

**Effective Date:** 1 April 2026

**Next Review Date:** 31 March 2027

**Approved By:** Board Risk & Compliance Committee

---

*This policy applies to all operations, branches, subsidiaries, and third-party service providers of the Bank operating within or in connection with the United Arab Emirates. It has been prepared in accordance with applicable UAE federal law, free zone regulations, and international best practices in data governance.*

---

## Table of Contents

1. [Purpose](#)
2. [Scope](#)
3. [Definitions](#)
4. [Regulatory Framework](#)
5. [Data Classification](#)
6. [Roles and Responsibilities](#)
7. [Data Protection Principles](#)
8. [Sensitive Data Handling](#)
9. [Access Control and Need-to-Know](#)
10. [Data Minimisation and Purpose Limitation](#)
11. [Cross-Border Data Transfers](#)
12. [AI Governance and Responsible Use of Technology](#)
13. [Monitoring, Audit, and Oversight](#)
14. [Incident Management and Breach Notification](#)
15. [Health Data — Special Provisions](#)
16. [Free Zone Operations — Jurisdictional Guidance](#)
17. [Third-Party and Vendor Management](#)
18. [Regulatory Compliance References](#)
19. [Exceptions and Deviations](#)
20. [Policy Review and Governance](#)
21. [Appendix A — Data Classification Reference Table](#)
22. [Appendix B — Jurisdictional Comparison Summary](#)

## **1. Purpose**

This policy establishes the Bank's enterprise-wide framework for the protection of personal data, sensitive financial information, and health-related data across all its operations in the United Arab Emirates (UAE). It reflects the Bank's commitment to responsible data stewardship, regulatory compliance, and the privacy rights of its customers, employees, and business partners.

The UAE's data protection landscape has evolved significantly, and the Bank recognises that operating within this jurisdiction — whether at the federal level or within the financial free zones of the Abu Dhabi Global Market (ADGM) or the Dubai International Financial Centre (DIFC) — requires a nuanced understanding of applicable legal obligations.

This policy ensures that all personnel, whether they are processing customer account details, handling identity documents such as Emirates ID or Aadhaar for resident Indian nationals, managing financial records, or operating technology platforms that process personal data, do so in a lawful, transparent, and accountable manner.

The policy further ensures that the Bank's use of automated systems, data analytics, and artificial intelligence in its operations is governed responsibly, with adequate human oversight and controls to prevent misuse of personal or sensitive information.

---

## **2. Scope**

### **2.1 Geographic Scope**

This policy applies to:

- All UAE branches and offices of the Bank operating under UAE federal law.
- All operations established within the Dubai International Financial Centre (DIFC).
- All operations established within the Abu Dhabi Global Market (ADGM).
- Any processing of personal data of UAE residents, regardless of where such processing occurs.

### **2.2 Functional Scope**

This policy applies to all business functions that collect, process, store, share, or dispose of personal or sensitive data, including but not limited to:

- Retail and corporate banking operations
- Credit and lending divisions

- Treasury and trade finance
- Human resources and payroll
- Information technology and digital banking
- Risk, compliance, and audit functions
- Marketing and customer engagement
- Third-party and outsourced operations

## 2.3 Personnel Scope

This policy is binding on:

- All permanent, contractual, and seconded employees
- Technology teams including developers, data engineers, and platform administrators
- Compliance officers, auditors, and risk managers
- Vendors, outsourced service providers, and third-party processors acting on behalf of the Bank

---

## 3. Definitions

| Term                           | Definition                                                                                                                                                                                                                                                  |
|--------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Personal Data</b>           | Any information relating to an identified or identifiable natural person. This includes names, contact details, financial account information, identification numbers, and any data that can be used — alone or in combination — to identify an individual. |
| <b>Sensitive Personal Data</b> | A subset of personal data that carries a higher risk of harm if disclosed without authorisation. This includes financial credentials, authentication information, health records, biometric data, and government-issued identity information.               |
| <b>Data Controller</b>         | The entity that determines the purposes and means of processing personal data. The Bank acts as a data controller in respect of customer and employee data.                                                                                                 |
| <b>Data Processor</b>          | An entity that processes personal data on behalf of the data controller. Vendors and technology service providers typically act as data processors.                                                                                                         |
| <b>Data Subject</b>            | The individual to whom the personal data relates — primarily customers, employees, and counterparties.                                                                                                                                                      |

| Term                                 | Definition                                                                                                                                                                          |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Data Protection Officer (DPO)</b> | The designated individual responsible for overseeing the Bank's compliance with applicable data protection laws and serving as a point of contact for regulators and data subjects. |
| <b>Processing</b>                    | Any operation performed on personal data, whether by automated or manual means, including collection, storage, use, transmission, modification, restriction, or deletion.           |
| <b>Lawful Basis</b>                  | The legal ground under which personal data may be processed, such as consent, contractual necessity, legal obligation, legitimate interest, or vital interest of the data subject.  |
| <b>Data Masking</b>                  | The practice of obscuring or replacing sensitive data fields with non-sensitive equivalents in environments where full data access is not required.                                 |
| <b>Data Redaction</b>                | The permanent removal or concealment of specific sensitive information from documents or records before they are shared or disclosed.                                               |
| <b>Pseudonymisation</b>              | The processing of personal data in such a manner that it can no longer be attributed to a specific individual without the use of additional, separately stored information.         |
| <b>Encryption</b>                    | The transformation of data into an unreadable format using cryptographic methods, such that it can only be read by authorised parties who hold the decryption key.                  |
|                                      |                                                                                                                                                                                     |
|                                      |                                                                                                                                                                                     |

## 4. Regulatory Framework

The Bank's UAE data protection obligations arise from a layered regulatory framework. The applicable law depends on the jurisdiction in which the Bank entity is incorporated, where its processing activities occur, and the nature of the data being handled.

### 4.1 Federal Law

#### UAE Personal Data Protection Law (PDP Law)

**Federal Law No. 45 of 2021** is the UAE's primary federal privacy statute. It introduces principles consistent with globally recognised standards, including lawful processing, transparency, data minimisation, and accountability. The PDP Law applies to any entity processing the personal data of UAE residents, whether processing occurs within or outside the UAE.

Key obligations under the PDP Law include:

- **Informed Consent:** Data subjects must be clearly informed of the purposes for which their personal data is collected. Consent must be informed, unambiguous, and easily withdrawable. This applies when the Bank onboards new customers and requires them to acknowledge how their customer name, phone number, email address, date of birth, and residential address will be used.
- **Data Subject Rights:** Individuals hold rights to access their data, request correction or erasure, obtain a portable copy, restrict processing, and object to automated decision-making that significantly affects them.
- **Data Protection Officer:** The Bank appoints a designated DPO responsible for overseeing compliance with this law. The DPO serves as the primary contact for the UAE Data Office, for data subjects exercising their rights, and for internal escalation of data protection concerns.
- **Breach Notification:** In the event of a data breach, the Bank is required to notify the UAE Data Office and affected individuals in a timely manner in accordance with prescribed timelines.
- **Cross-Border Transfers:** Transfer of personal data to countries outside the UAE is permitted only where the destination jurisdiction has been deemed adequate by the UAE Data Office, or where appropriate safeguards are in place.

The PDP Law does not apply to entities operating within UAE free zones that have enacted their own data protection legislation.

## UAE Health Data Law

**Federal Law No. 2 of 2019** governs the use of information technology in the healthcare sector. Unlike the PDP Law, the Health Data Law applies to all entities operating in the UAE — including those in the free zones — that provide healthcare-related services. Key provisions include:

- Healthcare data must be stored securely for a period of **25 years** from the date of the last medical procedure on the patient.
- Transfer of health data outside the UAE is generally prohibited except in specific circumstances permitted under **Ministerial Resolution No. 51 of 2021**.
- All healthcare providers must participate in centralised health data management systems such as NABIDH (Dubai Health Authority) to enable secure exchange of patient records.

## 4.2 DIFC Data Protection Law

**DIFC Law No. 5 of 2020** governs data protection within the Dubai International Financial Centre. It closely mirrors the principles of the European Union's General Data Protection Regulation (GDPR) and applies to all entities registered within the DIFC, as well as those offering goods or services to individuals located in the DIFC.

Under the DIFC Law, the Bank's DIFC-registered entity must ensure:

- A lawful basis exists for every processing activity involving customer or employee personal data.
- Data subjects can exercise rights of access, rectification, erasure, and portability.
- A DPO is designated for large-scale or sensitive data processing activities.
- Personal data transferred outside the DIFC benefits from adequate protection as assessed by the DIFC Commissioner of Data Protection.

#### **4.3 ADGM Data Protection Regulations**

**ADGM Data Protection Regulations 2021** apply to all entities within the Abu Dhabi Global Market. These regulations align closely with international data protection best practices and the GDPR framework. The Bank's ADGM-registered entity must:

- Identify and document a lawful basis (consent, contract, legal obligation, vital interest, or legitimate interest) for each processing activity.
  - Ensure that international data transfers are protected through adequacy decisions, standard contractual clauses, or binding corporate rules.
  - Appoint a DPO where required and engage proactively with the ADGM Office of Data Protection in the event of compliance reviews or investigations.
- 

### **5. Data Classification**

The Bank classifies all data it handles into four tiers. Classification determines the level of protection, access restrictions, and handling procedures that apply. All personnel are required to classify data correctly at the point of creation, collection, or receipt.

| Classification      | Description                                                                                                                                                                        | Examples                                                                                                          |
|---------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <b>Public</b>       | Information that is intentionally made available to the general public or that carries no risk of harm if disclosed.                                                               | Published annual reports, branch locations, product brochures.                                                    |
| <b>Internal</b>     | Information intended for use within the organisation that is not publicly disclosed. Disclosure outside the Bank without authorisation may cause reputational or operational harm. | Internal memos, organisational charts, process documentation.                                                     |
| <b>Confidential</b> | Sensitive business information and non-public personal data whose unauthorised disclosure could cause significant harm to the Bank, its customers, or counterparties.              | Customer account details, credit assessments, employee salary information, counterparty contract terms.           |
| <b>Restricted</b>   | The most sensitive tier, encompassing data whose compromise could result in regulatory sanctions, financial crime, identity theft, or serious harm to individuals.                 | Authentication credentials, cryptographic keys, health records, government identity documents, payment card data. |

Data classified as **Confidential** or **Restricted** must be encrypted both in transit and at rest. Access must be granted strictly on a need-to-know basis, with approvals documented and subject to periodic review.

## 6. Roles and Responsibilities

The effective implementation of this policy requires clearly defined responsibilities across all levels of the organisation. The following describes the key roles and their corresponding data protection obligations.

### 6.1 Board and Senior Management

The Board Risk and Compliance Committee has ultimate oversight responsibility for the Bank's data protection framework. Senior Management is accountable for ensuring that adequate resources, controls, and governance structures are in place. They approve this policy, review material incidents, and receive periodic reporting from the DPO.

### 6.2 Chief Compliance Officer (CCO)

The CCO is responsible for the overall governance of data protection compliance across all UAE jurisdictions. The CCO ensures that business activities are conducted in line

with applicable law and internal policy, and provides guidance on regulatory interpretation.

### **6.3 Data Protection Officer (DPO)**

The DPO operates independently and is responsible for:

- Monitoring compliance with UAE federal and free zone data protection laws.
- Maintaining the Bank's Record of Processing Activities (ROPA).
- Conducting and reviewing Data Protection Impact Assessments (DPIAs) for high-risk processing activities.
- Serving as the Bank's designated point of contact for the UAE Data Office, the DIFC Commissioner of Data Protection, and the ADGM Office of Data Protection.
- Receiving and managing data subject requests relating to access, correction, erasure, and objection.
- Reporting material data protection risks and incidents to Senior Management and the Board.

### **6.4 Compliance Officers**

Compliance Officers across business lines support the DPO in monitoring day-to-day adherence to data protection obligations. They may review inspection findings, assess the adequacy of data handling procedures within their business unit, and escalate concerns to the DPO. Compliance Officers do not have authority to modify security controls or override access restrictions.

### **6.5 Information Security Team**

The Information Security team is responsible for implementing and maintaining technical controls that protect personal and sensitive data. This includes managing encryption standards, monitoring access to Restricted and Confidential data, and responding to security alerts. The Security Administrator role within this team holds elevated access privileges necessary for the configuration and management of security infrastructure.

### **6.6 Platform Administrators**

Platform Administrators are responsible for configuring and managing the Bank's enterprise technology platforms. They hold the necessary system-level access to maintain platform availability and apply security configurations. Platform Administrators may not access, copy, or use personal customer data beyond what is strictly necessary to fulfil their platform maintenance responsibilities. All administrative actions are subject to logging and periodic review.

### **6.7 Architects and Technology Design Teams**

Technology Architects define the Bank's data architecture and governance standards. They approve the design of systems that process personal or sensitive data and ensure

that privacy-by-design principles are embedded into new technology solutions from the outset. Architects define governance standards and approve security designs before any new system is deployed into a production environment.

## **6.8 Data Engineers**

Data Engineers are responsible for building and maintaining data pipelines, transformation logic, and analytical datasets. They may process approved datasets under defined data governance rules but must not access raw, unmasked customer data unless explicitly authorised for a specific purpose. Where data masking or pseudonymisation is in place, Data Engineers must operate within masked environments.

## **6.9 AI Engineers and Analytics Teams**

AI Engineers design, build, and maintain machine learning models and automated decision-support tools. They may work with approved, appropriately de-identified datasets under the supervision of the AI Governance function. AI Engineers must not use personal customer data — including customer names, account numbers, loan details, or identity information — for model training without explicit approval from the DPO and AI Governance Officer. Model outputs that affect individual customers must be subject to human review before being acted upon.

## **6.10 Developers**

Developers may process approved datasets for the purpose of building and testing Bank applications. They may not access production customer data in development or testing environments without authorisation. Developers cannot modify enterprise security policies, override access controls, or deploy changes to production systems without following the Bank's approved change management process.

## **6.11 Auditors**

Internal and external Auditors may review logs, reports, access records, and data processing documentation for the purpose of assessing compliance. Auditors operate with read-only access to relevant systems and records and may not modify production resources, alter audit logs, or take actions that could affect the integrity of the data or systems they are reviewing.

## **6.12 Third-Party Service Providers**

All vendors, outsourced service providers, and technology partners who process personal data on behalf of the Bank are required to operate within the terms of a Data Processing Agreement (DPA). Third parties must demonstrate compliance with applicable UAE data protection laws and are subject to periodic due diligence assessments conducted by the Compliance and Information Security teams.

---

# **7. Data Protection Principles**

All processing of personal data by the Bank must conform to the following principles, which reflect both the requirements of UAE law and the Bank's own governance standards.

### **7.1 Lawfulness, Fairness, and Transparency**

The Bank processes personal data only where a valid legal basis exists. Processing activities are documented and communicated to data subjects through clear and accessible privacy notices. Customers are informed at the point of data collection — whether onboarding for a bank account, applying for a loan, or using the Bank's digital platforms — of the purposes for which their information will be used.

### **7.2 Purpose Limitation**

Personal data collected for one purpose must not be used for an unrelated purpose without either a new lawful basis or the data subject's renewed consent. For example, a customer's mobile phone number collected for transaction alert notifications must not be used for unsolicited marketing without separate consent.

### **7.3 Data Minimisation**

The Bank collects only the data that is strictly necessary for the stated purpose. When designing new processes or systems, business owners and architects must consider whether a less data-intensive approach could achieve the same objective. Requests to collect or retain additional personal data fields must be justified and approved.

### **7.4 Accuracy**

The Bank takes reasonable steps to ensure that the personal data it holds is accurate and kept up to date. Customers are provided with mechanisms to update their personal information, including residential address, contact number, and email address, through the Bank's digital and branch channels.

### **7.5 Storage Limitation**

Personal data is retained only for as long as is necessary to fulfil the purpose for which it was collected, or as required by applicable law or regulatory guidance. Retention schedules are maintained by the Records Management team and reviewed annually. At the end of the retention period, data is securely deleted or anonymised.

### **7.6 Integrity and Confidentiality**

All personal data — particularly Restricted data such as bank account numbers, credit card numbers, UPI IDs, MPIN, OTPs, API keys, and authentication tokens — must be protected against unauthorised access, loss, destruction, or alteration. Encryption, access controls, and monitoring are the primary technical mechanisms used to uphold this principle.

## 7.7 Accountability

The Bank maintains documentation of all processing activities and can demonstrate compliance with applicable data protection laws. The DPO bears primary responsibility for this accountability function, supported by the Compliance, Information Security, and Legal teams.

---

## 8. Sensitive Data Handling

The Bank handles a wide variety of sensitive personal and financial information in the course of its operations. This section describes the categories of sensitive data processed by the Bank, the risks they present, and the specific controls that apply to their handling.

### 8.1 Identity Information

The Bank collects and verifies government-issued identity documents as part of its Know Your Customer (KYC) obligations under applicable anti-money laundering and counter-terrorism financing regulations. Identity documents processed by the Bank include:

- **Emirates ID** (for UAE residents)
- **Passport Number** (for expatriate and international customers)
- **Aadhaar Number and PAN Number** (for Indian nationals in the context of cross-border banking relationships or NRI accounts)
- **Driving Licence**
- **Voter ID** (where applicable)
- **GSTIN** (for business customers)

Identity information is classified as **Restricted**. It may only be accessed by authorised personnel with a verified need to fulfil KYC, fraud prevention, or legal compliance obligations. Storage of identity data must be encrypted, and any physical copies must be managed under document security procedures. Identity data must not be shared with third parties beyond what is required for regulatory compliance.

### 8.2 Customer Personal Information

The following personal information categories are collected from and about customers and are classified as **Confidential** or **Restricted** depending on the context of use:

- Customer Name
- Email Address
- Phone Number
- Date of Birth
- Residential Address

This information forms the core of the Bank's customer profile and must be handled in accordance with the purpose limitation and data minimisation principles. Access to customer personal information systems is logged, and any bulk extraction of customer records requires explicit approval from the DPO and a documented business justification.

### 8.3 Financial Information

The Bank processes a broad range of financial data in connection with its core banking activities. The following are among the most sensitive financial data types and are classified as **Restricted**:

- Bank Account Number
- IFSC Code
- Credit Card Number
- Debit Card Number
- UPI ID
- Customer ID / Customer Information File (CIF) Number
- Loan Account Number

Financial information must never be transmitted in plain text over unsecured channels. It must not be included in unstructured communications such as email unless encrypted end-to-end. Access to financial information is restricted to personnel with a direct operational need, and this access is reviewed on a quarterly basis.

### 8.4 Authentication and Credential Information

Authentication information represents the most sensitive category of data processed by the Bank because its compromise directly enables fraud, identity theft, or unauthorised system access. The following are classified as **Restricted** and subject to the most stringent controls:

- Passwords and PINs
- MPIN (Mobile Banking PIN)
- OTP (One-Time Password)
- API Keys
- Private Cryptographic Keys
- Authentication Tokens
- JWT Tokens (JSON Web Tokens)

Authentication credentials must never be stored in plain text. They must never be logged in system logs, application traces, or error messages. Personnel who administer systems that generate or validate credentials must operate under dual-control principles where operationally feasible. Any suspected compromise of an authentication credential must

be reported to the Information Security team immediately for revocation and investigation.

## 8.5 Health and Medical Information

Where the Bank offers insurance-linked or health-tied financial products, or where employees voluntarily provide health information in connection with workplace health benefits, the following categories of data may be processed:

- Medical Records and Diagnoses
- Health Insurance Policy Information
- Details of medical procedures (relevant to the Health Data Law retention obligations)

Health information is classified as **Restricted** and is subject to the provisions of UAE Federal Law No. 2 of 2019 (Health Data Law), regardless of whether the Bank's entity is in a free zone. Access to health data is restricted to the HR Benefits team and relevant insurance processing personnel. Health data must not be processed for any purpose other than the administration of the benefit or service for which it was provided.

---

## 9. Access Control and Need-to-Know

### 9.1 Principle of Least Privilege

Access to personal and sensitive data systems is granted on the basis of the principle of least privilege — meaning that each individual is given the minimum level of access necessary to perform their defined role. No individual is granted access to data categories that are not directly relevant to their current job responsibilities.

Access privileges are reviewed at a minimum every six months. Any change in role, department, or employment status triggers an immediate access review.

### 9.2 Need-to-Know

Beyond technical access rights, the Bank applies a need-to-know standard. Even where an individual has technical access to a system, they are expected to access only the specific records, reports, or datasets required for their assigned task. Accessing customer records without a documented business reason — even where technical access permits it — constitutes a policy violation and may result in disciplinary action.

### 9.3 Access Approval and Documentation

All requests for access to Restricted or Confidential data systems must go through a documented approval workflow. Requests must include a business justification, the name of the approving manager, and the specific data categories to be accessed. Access approvals are stored for audit purposes for a minimum of three years.

## **9.4 Privileged Access Management**

Platform Administrators, Security Administrators, and Cloud Administrators who hold elevated technical privileges in enterprise systems are subject to enhanced monitoring and additional approval requirements. Privileged access sessions are logged in full, and logs are reviewed regularly by the Audit and Information Security teams. Privileged accounts must not be used for routine, non-administrative tasks.

## **9.5 Periodic Access Review**

The Information Security team, in coordination with HR and business line managers, conducts periodic access reviews to ensure that access rights remain appropriate. Stale accounts, unused access, and over-provisioned roles are decommissioned promptly. The results of access reviews are reported to the DPO and the Board Risk and Compliance Committee on a semi-annual basis.

---

# **10. Data Minimisation and Purpose Limitation**

## **10.1 Collect Only What Is Necessary**

Business teams must conduct a data necessity assessment before introducing any new data collection requirement. They must be able to demonstrate that each data field collected is necessary for the stated processing purpose. This assessment must be documented and submitted to the DPO for review where the data involved is of a sensitive nature.

## **10.2 Define and Communicate Purpose**

The purpose for which any personal data is collected must be defined before collection begins. This purpose must be communicated to the data subject through the Bank's privacy notices. Any use of previously collected data for a new, different purpose requires either a new legal basis or renewed consent.

## **10.3 Data Masking and Redaction in Non-Production Environments**

Production customer data — including account numbers, loan balances, identity numbers, and contact details — must not be used in development, testing, or analytical environments without first being masked or pseudonymised. Data Engineers and Developers working in non-production environments must operate exclusively with masked datasets. The Data Engineering team is responsible for implementing and maintaining approved masking processes, with oversight from the Information Security team.

Where a document containing personal data must be shared externally for a limited purpose, sensitive fields that are not relevant to the purpose of sharing must be redacted before transmission.

---

## 11. Cross-Border Data Transfers

### 11.1 Jurisdictional Assessment

The Bank operates across multiple jurisdictions, and the movement of personal data across borders requires careful legal assessment. The applicable rules differ based on the jurisdiction from which the data originates:

- Data controlled by the Bank's entities subject to the **UAE PDP Law** may only be transferred to countries deemed adequate by the UAE Data Office, or where appropriate safeguards are documented.
- Data controlled by the Bank's **DIFC-registered entity** may only be transferred internationally where the recipient jurisdiction has been assessed as providing adequate protection by the DIFC Commissioner of Data Protection.
- Data controlled by the Bank's **ADGM-registered entity** may be transferred internationally where the destination jurisdiction provides an adequate level of protection, or where standard contractual clauses or binding corporate rules are in place.

### 11.2 Health Data — Special Restrictions

Transfer of health data outside the UAE is subject to stricter controls under Federal Law No. 2 of 2019. Such transfers are only permissible in the specific circumstances enumerated under Ministerial Resolution No. 51 of 2021. Any proposed cross-border transfer of health data must be reviewed and approved by the DPO and the Legal team before it is initiated.

### 11.3 Transfer Documentation

All approved cross-border data transfers must be documented, including the data categories transferred, the recipient entity, the legal basis for transfer, and the safeguards in place. This documentation is maintained by the DPO as part of the Bank's Record of Processing Activities (ROPA) and is available for review by regulatory authorities upon request.

---

## 12. AI Governance and Responsible Use of Technology

The Bank increasingly uses automated systems, data analytics, and artificial intelligence to support its operations — including credit scoring, fraud detection, customer segmentation, and regulatory reporting. The use of such systems must be governed responsibly to ensure fairness, accountability, and the protection of customer rights.

### 12.1 AI Governance Principles

The Bank's use of AI and automated decision-making is governed by the following

principles:

- **Human Oversight:** Any AI-generated decision that materially affects a customer — such as a credit refusal, a fraud flag leading to account suspension, or a KYC determination — must be subject to human review before being acted upon. Automated decisions must not be implemented without a defined human escalation pathway.
- **Responsible AI:** AI systems must be designed and operated in a manner that is fair, explainable, and consistent with the Bank's obligations to its customers and regulators. The AI Governance Officer is responsible for establishing and maintaining the Bank's AI ethics standards.
- **AI Risk Management:** Before any AI model is deployed in a production environment affecting customer data or regulatory processes, it must undergo a documented risk assessment, covering model accuracy, bias testing, data quality, and security considerations. This assessment is reviewed by the AI Governance Officer and approved by the Chief Risk Officer.
- **Secure AI Development:** AI Engineers must follow secure development practices, including validation of model inputs to prevent prompt injection attacks, validation of model outputs before they are used in customer-facing or regulatory processes, and the use of approved, appropriately protected datasets for model training.
- **Model Input Validation:** Systems that accept free-text or external inputs must implement controls to detect and prevent attempts to manipulate model behaviour through adversarial inputs or prompt injection techniques.
- **Output Validation:** Model outputs, particularly those used to drive customer-impacting decisions, must be validated for reasonableness before use. Anomalous or unexpected outputs must be flagged for human review.

## 12.2 Prohibited AI Practices

The Bank prohibits the following:

- Using unmasked personal customer data — including bank account numbers, customer IDs, loan details, date of birth, or identity document numbers — for AI model training without explicit DPO approval and a documented data governance clearance.
- Deploying AI models in production without prior risk assessment and governance approval.
- Using AI systems to make fully automated decisions that significantly and adversely affect customers without providing those customers with a right to request human review.
- Using AI to process special category data (including health information) for purposes not disclosed in the Bank's privacy notices.

### **12.3 Alignment with AI Standards**

The Bank's AI governance framework is designed to be consistent with the principles of **ISO/IEC 42001** (AI Management Systems) and the **NIST AI Risk Management Framework (AI RMF)**, and takes into account emerging regulatory guidance on AI in financial services.

---

## **13. Monitoring, Audit, and Oversight**

### **13.1 Audit Logging**

The Bank maintains comprehensive audit logs for all access to systems containing personal or sensitive data. Audit logs capture, at a minimum:

- The identity of the individual or system accessing data
- The date and time of access
- The data category accessed
- The action performed (view, modify, extract, delete)
- The source system or application used

Audit logs for Restricted data systems are retained for a minimum of five years. Logs must not be modified, deleted, or tampered with. Any attempt to alter audit logs is treated as a serious security incident.

### **13.2 Continuous Monitoring**

The Information Security team monitors access patterns and data processing activities on an ongoing basis to detect anomalies, unauthorised access, or potential data breaches. Automated alerts are configured to flag unusual patterns, such as bulk data extractions, access from unrecognised locations, or access to high-sensitivity datasets outside business hours.

### **13.3 Auditor Access**

Auditors — whether internal audit team members or external regulatory inspectors — may access audit logs, processing records, access control documentation, and system reports for the purpose of compliance assessment. Auditors are granted read-only access to relevant systems and may not take any action that would alter records, modify system configurations, or affect the integrity of the data being reviewed.

### **13.4 DPO Oversight**

The DPO reviews audit reports on a quarterly basis and raises material concerns to Senior Management. The DPO also coordinates external audits by data protection authorities, including inspections by the UAE Data Office, the DIFC Commissioner of Data Protection, and the ADGM Office of Data Protection.

Where required by applicable law, the Bank submits periodic data protection reports to relevant regulatory authorities. The DPO is responsible for coordinating these submissions and ensuring their accuracy and completeness.

---

## **14. Incident Management and Breach Notification**

### **14.1 Definition of a Data Breach**

A data breach is any event involving the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. This includes, but is not limited to:

- Unauthorised access to customer accounts or personal records
- Theft or loss of a device containing unencrypted customer data
- Inadvertent disclosure of customer financial information to an unintended recipient
- Ransomware or malware affecting systems storing personal data
- A vendor reporting that personal data shared by the Bank has been compromised

### **14.2 Incident Reporting**

All Bank employees and third-party partners must report suspected or confirmed data breaches to the Information Security team and the DPO immediately upon becoming aware. Delay in reporting a known breach is itself a policy violation and may attract regulatory sanction.

### **14.3 Breach Assessment and Response**

Upon receipt of an incident report, the Information Security team conducts an initial triage to assess:

- The nature and scope of the breach
- The categories and approximate number of individuals affected
- The likely consequences for affected individuals
- The measures taken or proposed to address the breach

### **14.4 Regulatory Notification**

**Under the UAE PDP Law (Federal):** The Bank must notify the UAE Data Office in accordance with prescribed timelines following confirmation of a breach. Affected individuals must also be notified where the breach is likely to result in a high risk to their rights and freedoms.

**Under the DIFC Law:** Breaches must be reported to the DIFC Commissioner of Data Protection without undue delay.

**Under the ADGM Regulations:** The Bank must notify the ADGM Office of Data Protection in line with regulatory requirements.

Where the same breach affects individuals across multiple jurisdictions, the DPO coordinates a consolidated notification strategy to ensure compliance with all applicable obligations.

#### **14.5 Post-Incident Review**

Following resolution of a data breach, the Information Security and Compliance teams conduct a formal post-incident review to identify root causes, evaluate the adequacy of the Bank's response, and implement corrective measures to reduce the risk of recurrence. The findings of this review are reported to Senior Management and the Board Risk and Compliance Committee.

---

### **15. Health Data — Special Provisions**

The UAE Health Data Law (Federal Law No. 2 of 2019) applies to all entities that provide healthcare-related services in the UAE, including within the financial free zones. To the extent the Bank facilitates health insurance products or employee health benefit programmes, the following special provisions apply.

#### **15.1 Scope of Health Data**

Health data processed by the Bank includes:

- Medical records and diagnoses of employees (for workplace health benefits)
- Health insurance policy details and claims information
- Records of medical procedures (relevant to the 25-year retention obligation under the Health Data Law)

#### **15.2 Access to Health Data**

Access to health data is restricted to authorised personnel in the HR Benefits administration function and to insurers or healthcare providers acting as authorised processors under a Data Processing Agreement. Health data must not be accessed by, or disclosed to, any other business unit or individual without explicit authorisation from the DPO.

#### **15.3 Interoperability and NABIDH**

Where the Bank operates in connection with healthcare facilities subject to the Dubai Health Authority's NABIDH platform, the Bank's technology and operations teams must ensure that data exchange with NABIDH is conducted using approved, compliant

Electronic Medical Record (EMR) systems. Data shared via NABIDH must conform to UAE Digital Data Interoperability Framework standards.

15.4 Cross-Border Transfer of Health Data

Health data must not be transferred outside the UAE without prior review and approval from the DPO and Legal team, and only in the circumstances permitted under Ministerial Resolution No. 51 of 2021.

16. Free Zone Operations — Jurisdictional Guidance

16.1 Understanding Jurisdictional Scope

A critical consideration for the Bank's operations in the UAE is that the applicable data protection law depends on the jurisdiction in which each legal entity is registered. Business teams must not assume that a single policy or approach satisfies all jurisdictional requirements without consulting with the DPO.

| Entity                 | Applicable Primary Law                   | Regulatory Authority                 |
|------------------------|------------------------------------------|--------------------------------------|
| UAE Federal Branch     | UAE PDP Law (Federal Law No. 45 of 2021) | UAE Data Office                      |
| DIFC-Registered Entity | DIFC Law No. 5 of 2020                   | DIFC Commissioner of Data Protection |
| ADGM-Registered Entity | ADGM Data Protection Regulations 2021    | ADGM Office of Data Protection       |

In all cases, Federal Law No. 2 of 2019 (Health Data Law) applies in addition to the above where health data is being processed.

16.2 Similarities Across Frameworks

The Bank notes that all three frameworks share core principles drawn from international data protection standards, including lawful basis requirements, data subject rights, obligations to appoint a DPO for high-risk processing, and requirements around cross-border data transfers. This alignment allows the Bank to implement a common baseline of data protection controls while tailoring specific compliance measures to each jurisdiction.

16.3 Key Distinctions

Despite their common foundations, the three frameworks have important distinctions:

- The **PDP Law** provides for consent exceptions to account for public security considerations, reflecting its federal character. It generally adopts a less

prescriptive approach to fines and enforcement compared to the free zone laws.

- The **DIFC and ADGM laws** are comparatively more prescriptive, reflecting their regulated financial centre environments. They impose higher standards in certain areas, including DPO requirements and data subject rights.
  - The **DIFC and ADGM laws** do not benefit from a "public security" processing exemption in the same manner as the PDP Law.
- 

## **17. Third-Party and Vendor Management**

### **17.1 Vendor Due Diligence**

Before engaging any third party that will process personal data on behalf of the Bank, the Procurement and Information Security teams must conduct a data protection due diligence assessment. This assessment evaluates the vendor's data security practices, their compliance with applicable UAE data protection law, and their ability to meet the Bank's contractual requirements.

### **17.2 Data Processing Agreements**

All third parties acting as data processors must enter into a Data Processing Agreement (DPA) with the Bank before any personal data is shared or made accessible. The DPA must address:

- The categories of personal data being processed
- The purpose and duration of processing
- Security and confidentiality obligations
- Restrictions on sub-processing
- Obligations on data breach notification
- Data return or deletion upon termination
- Rights of the Bank to audit the vendor's data protection practices

### **17.3 Ongoing Monitoring**

The relationship with third-party processors does not end at contract signature. The Compliance team is responsible for conducting periodic reviews of vendor compliance with the DPA and applicable law. Material changes in a vendor's data processing practices must be reported to the Bank and approved by the DPO.

---

## **18. Regulatory Compliance References**

The Bank's data protection framework is informed by, and designed to be consistent with, the following regulatory and standards frameworks:

| Framework                                                     | Relevance                                                                                                                |
|---------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| <b>UAE Federal Law No. 45 of 2021 (PDP Law)</b>               | Primary federal data privacy obligation for UAE operations                                                               |
| <b>UAE Federal Law No. 2 of 2019 (Health Data Law)</b>        | Health data processing and retention requirements across all UAE jurisdictions                                           |
| <b>DIFC Law No. 5 of 2020</b>                                 | Data protection obligations for DIFC-registered entities                                                                 |
| <b>ADGM Data Protection Regulations 2021</b>                  | Data protection obligations for ADGM-registered entities                                                                 |
| <b>EU General Data Protection Regulation (GDPR)</b>           | Applies where the Bank processes personal data of EU residents; also serves as the baseline model for DIFC and ADGM laws |
| <b>PCI DSS (Payment Card Industry Data Security Standard)</b> | Governs the protection of credit card and debit card data processed by the Bank                                          |
| <b>ISO/IEC 27001</b>                                          | International standard for information security management systems                                                       |
| <b>ISO/IEC 42001</b>                                          | International standard for AI management systems                                                                         |
| <b>NIST AI Risk Management Framework (AI RMF)</b>             | Guidance framework for responsible AI development and deployment                                                         |
| <b>UAE National Cybersecurity Strategy</b>                    | National framework for cybersecurity resilience across all sectors                                                       |
| <b>UAE Digital Data Interoperability Framework</b>            | Standards for data classification, exchange, and quality                                                                 |
| <b>Internal Information Security Policy</b>                   | The Bank's enterprise-wide information security governance standards                                                     |

## 19. Exceptions and Deviations

Any request to deviate from the requirements of this policy must be submitted in writing to the DPO and the Chief Compliance Officer. Requests must include:

- A clear description of the proposed deviation
- The business justification
- An assessment of the risks arising from the deviation

- Proposed compensating controls
- The duration of the exception

Exceptions may only be granted by the DPO in consultation with the CCO, and must be documented with a defined review date. No exception shall be granted that would place the Bank in breach of applicable law.

---

## 20. Policy Review and Governance

This policy is reviewed annually, or earlier in the event of:

- Material changes to applicable UAE data protection law or regulatory guidance
- A significant data breach or enforcement action
- Introduction of new data processing activities or technologies
- Changes to the Bank's corporate structure or jurisdictional footprint

All revisions are approved by the Board Risk and Compliance Committee before taking effect. Employees are notified of material changes through the Bank's internal communication channels and are required to confirm their understanding of the updated policy.

---

## Appendix A — Data Classification Reference Table

| Data Type                     | Classification | Examples                                                                                                              | Key Handling Requirements                                                            |
|-------------------------------|----------------|-----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Government Identity Documents | Restricted     | Emirates ID, Passport, Aadhaar Number, PAN Number, Driving Licence, Voter ID, GSTIN                                   | Encrypt at rest and in transit. Access by authorised KYC personnel only.             |
| Customer Personal Information | Confidential   | Customer Name, Email Address, Phone Number, Date of Birth, Residential Address                                        | Controlled access. Purpose-limited use. Masked in non-production environments.       |
| Financial Account Data        | Restricted     | Bank Account Number, IFSC Code, Credit Card Number, Debit Card Number, UPI ID, CIF / Customer ID, Loan Account Number | Encrypt always. Never transmit in plain text. Access restricted to operational need. |

---

| Data Type                      | Classification | Examples                                                                       | Key Handling Requirements                                                                                        |
|--------------------------------|----------------|--------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| Authentication Credentials     | Restricted     | Password, MPIN, OTP, API Keys, Private Keys, Authentication Tokens, JWT Tokens | Never store in plain text. Never log. Immediate revocation on suspected compromise.                              |
| Health and Medical Information | Restricted     | Medical Records, Health Insurance Information, Procedure History               | Strictly limited access. 25-year retention under Health Data Law. No cross-border transfer without DPO approval. |
| Internal Business Information  | Internal       | Memos, Process Documentation, Organisational Charts                            | Standard access controls. Not for external disclosure without approval.                                          |
| Public Information             | Public         | Published Reports, Product Brochures, Branch Locations                         | No special handling required.                                                                                    |

## Appendix B — Jurisdictional Comparison Summary

| Feature                     | UAE PDP Law (Federal)                               | DIFC Law                                               | ADGM Regulations                                    |
|-----------------------------|-----------------------------------------------------|--------------------------------------------------------|-----------------------------------------------------|
| Primary Legal Instrument    | Federal Law No. 45 of 2021                          | DIFC Law No. 5 of 2020                                 | ADGM Data Protection Regulations 2021               |
| Applies to Free Zones?      | No (except Health Data Law)                         | DIFC only                                              | ADGM only                                           |
| GDPR-Inspired?              | Partially                                           | Strongly                                               | Strongly                                            |
| DPO Required?               | For high-risk / large-scale processing              | For large-scale / sensitive data                       | For significant / sensitive processing              |
| Cross-Border Transfer Rules | Adequacy or safeguards (UAE Data Office)            | Adequacy or safeguards (DIFC Commissioner)             | Adequacy, SCCs, or BCRs (ADGM ODP)                  |
| Data Subject Rights         | Access, Correction, Erasure, Portability, Objection | Access, Rectification, Erasure, Portability, Objection | Access, Correction, Erasure, Portability, Objection |

| Feature                    | UAE PDP Law<br>(Federal) | DIFC Law                             | ADGM Regulations               |
|----------------------------|--------------------------|--------------------------------------|--------------------------------|
| Public Security Exception? | Yes                      | Limited                              | Limited                        |
| Regulatory Body            | UAE Data Office          | DIFC Commissioner of Data Protection | ADGM Office of Data Protection |
| Breach Notification?       | Yes                      | Yes                                  | Yes                            |

## Appendix C — Glossary of Regulatory Bodies

| Body                                                         | Jurisdiction                         | Role                                                                                                                               |
|--------------------------------------------------------------|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| UAE Data Office                                              | Federal UAE                          | Primary federal regulator for data protection under the PDP Law. Not yet fully operational at time of writing.                     |
| DIFC Commissioner of Data Protection                         | Dubai International Financial Centre | Enforces the DIFC Data Protection Law. Investigates complaints, conducts audits, and issues fines for non-compliance.              |
| ADGM Office of Data Protection                               | Abu Dhabi Global Market              | Enforces the ADGM Data Protection Regulations. Can monitor compliance, investigate complaints, advise courts, and issue sanctions. |
| Dubai Health Authority (DHA)                                 | Dubai                                | Oversees healthcare data governance in Dubai, including the NABIDH health information exchange platform.                           |
| UAE National Electronic Security Authority                   | Federal UAE                          | Implements the UAE National Cybersecurity Strategy and oversees cybersecurity resilience across all sectors.                       |
| Abu Dhabi Healthcare Information and Cyber Security (ADHICS) | Abu Dhabi                            | Sets standards for the confidentiality, integrity, and availability of healthcare information in Abu Dhabi.                        |

*This document has been approved by the Board Risk and Compliance Committee and is effective as at the date stated on the cover page. Queries regarding interpretation or*

*application of this policy should be directed to the Data Protection Officer.*

*© 2026 — Internal Document. Not for External Distribution.*